

Reporte Ejecutivo - Gestión de Riesgos

Clínica privada - TP Seguridad de Sistemas

Resumen ejecutivo

La clínica analizada posee 120 empleados, atiende aproximadamente 800 pacientes diarios y depende de sistemas digitales para historias clínicas, datos de obras sociales y facturación. El análisis identifica riesgos relevantes de confidencialidad, integridad, disponibilidad y continuidad operativa. La prioridad es reducir la probabilidad y el impacto de incidentes que puedan interrumpir la atención o exponer información sensible.

Top 5 riesgos

Riesgo	P	I	Nivel
Ransomware en historias clínicas	4	5	20 Alto
Phishing a personal administrativo	4	4	16 Alto
Acceso indebido a historias clínicas	3	5	15 Alto
Caída del sistema de historias clínicas	3	5	15 Alto
Fuga de datos de obras sociales	3	5	15 Alto

Estado de los planes de acción

Plan	Riesgo	Estado
Backups offline/inmutables + recuperación	Ransomware	Propuesto
MFA + capacitación anti-phishing	Phishing	Propuesto
Revisión RBAC + auditoría de accesos	Acceso indebido	Propuesto

Recomendaciones prioritarias

- 1) Implementar MFA y fortalecer la capacitación contra phishing.
- 2) Mantener copias de respaldo offline o inmutables y probar periódicamente la recuperación.
- 3) Aplicar mínimo privilegio y revisión periódica de accesos a historias clínicas.

- 4) Monitorear disponibilidad de sistemas críticos y establecer procedimientos de continuidad.
- 5) Proteger físicamente la infraestructura: los centros de datos no deben ubicarse junto a cocinas ni debajo de piletas, reduciendo exposición a incendio e inundación.

Analogía solicitada

El lobo feroz y Caperucita Roja representan una amenaza externa que intenta aprovechar una debilidad. Los tres cerditos representan capas de defensa: una sola barrera puede fallar, por lo que se recomienda combinar controles preventivos, detectivos y de recuperación.

Criterio de gestión

La matriz utilizada prioriza el riesgo mediante Probabilidad × Impacto. Los resultados son estimaciones académicas y deben validarse con datos de la clínica. Se recomienda mantener propietarios, fechas y evidencias de tratamiento en SimpleRisk y revisar el registro periódicamente.

Nota

Los estados de los planes se presentan como propuestos para evitar afirmar una implementación que todavía debe realizarse en la instancia de SimpleRisk del estudiante.